

TP : Analyse d'un Trojan Downloader

 **IMPORTANT:** Malware éducatif - VM isolée obligatoire

Objectifs

Analyser un Trojan Downloader combinant analyse statique et dynamique pour identifier:

- Communication C2 (Command & Control)
- Mécanismes de persistance
- Téléchargement de payload secondaire
- Indicateurs de compromission (IOCs)

Prérequis

Environnement:

- VM Linux isolée (snapshot avant analyse)
- Python 3 installé

Outils:

```
sudo apt install -y strace tcpdump inotify-tools python3
```

Structure

```
MalwareAnalysis/  
├── sample/  
│   ├── trojan_downloader.py    # Trojan à analyser  
│   └── README.md               # Ce fichier
```

PHASE 1 : Analyse Statique

Exercice 1.1 : Métadonnées

```
cd MalwareAnalysis/sample  
  
# Hash MD5 et SHA256  
md5sum trojan_downloader.py  
sha256sum trojan_downloader.py  
  
# Type et taille
```

```
file trojan_downloader.py
ls -lh trojan_downloader.py
```

Questions:

1. Notez les hashes (MD5 et SHA256)
2. Quelle est la taille du fichier ?

Exercice 1.2 : Extraction des Strings

```
# Chercher des patterns suspects
strings trojan_downloader.py | grep -i "http\|ip\|c2\|gate\|mutex\|payload"
```

Questions:

1. Quelle adresse IP est présente ? Comment est-elle cachée ?
2. Quel endpoint HTTP est utilisé ?
3. Quel User-Agent est envoyé ?
4. Quel est le nom du mutex ?
5. Où le malware s'installe-t-il ?

Exercice 1.3 : Analyse du Code

Ouvrez `trojan_downloader.py` et répondez:

A. Configuration C2

1. Décodez la variable `C2`
2. Décodez `PORT`
3. Quelle est l'URL complète du C2 ?

B. Persistence 4. Où le trojan se copie-t-il ? 5. Quel fichier assure le lancement automatique ? 6. Comment supprimer la persistance ?

C. Communication 7. Quelle méthode HTTP est utilisée ? 8. Que contient le payload envoyé au C2 ? Comment est-il généré ? 9. Que cherche le trojan dans la réponse du C2 ?

D. Payload Secondaire 10. Où le payload est-il téléchargé ? 11. Comment est-il exécuté ?



PHASE 2 : Analyse Dynamique

Exercice 2.1 : Surveillance Fichiers

Terminal 1 - Monitoring:

```
inotifywait -m -r ~/.local ~/.config \  
-e create,modify,delete \  
--format '%T %e %f' --timefmt '%H:%M:%S'
```

Terminal 2 - Exécution:

```
cd /root/Cours/MalwareAnalysis/sample  
python3 trojan_downloader.py
```

Questions:

1. Quels fichiers ont été créés ?
 2. Dans quels répertoires ?
-

Exercice 2.2 : Trace des Appels Système

```
rm -rf /tmp/.trojan_mutex_A5B3C2D1  
  
strace -f -e trace=openat,connect,socket,execve \  
-o /tmp/strace.log \  
python3 trojan_downloader.py 2>&1  
  
# Analyser les connexions réseau  
grep "connect" /tmp/strace.log
```

Questions:

1. Quelle connexion réseau est tentée ? (IP:Port) - *Si non visible dans strace, utilisez l'analyse statique de la Phase 1*
 2. Quels fichiers sont créés ?
 3. Y a-t-il exécution d'un processus enfant ?
 4. Pourquoi fait-on `rm -rf /tmp/.trojan_mutex_A5B3C2D1` avant ?
-

Exercice 2.3 : Capture Réseau

Terminal 1 - Capture:

```
sudo tcpdump -i any -w /tmp/c2_traffic.pcap 'port 8080'
```

Terminal 2 - Exécution:

```
python3 trojan_downloader.py
```

Analyse (Terminal 1, après Ctrl+C):

```
sudo tcpdump -r /tmp/c2_traffic.pcap -A
```

Questions:

1. Y a-t-il du trafic capturé ? Pourquoi ?
2. Si oui, quel est le contenu de la requête HTTP ?
3. Quelle information est envoyée au C2 ?



PHASE 3 : Rapport IOCs

Complétez ce rapport:

```
=== RAPPORT D'ANALYSE MALWARE ===

--- INFORMATIONS DE BASE ---
Nom: trojan_downloader.py
Hash MD5: [VOTRE RÉPONSE]
Hash SHA256: [VOTRE RÉPONSE]
Taille: [VOTRE RÉPONSE]

--- CLASSIFICATION ---
Famille: [VOTRE RÉPONSE]
Niveau de menace: [Faible/Moyen/Élevé]

--- COMPORTEMENT OBSERVÉ ---
Persistance:
- Mécanisme: [VOTRE RÉPONSE]
- Fichier autostart: [VOTRE RÉPONSE]
- Copie malware: [VOTRE RÉPONSE]

Communication C2:
- Serveur: [VOTRE RÉPONSE]
- Port: [VOTRE RÉPONSE]
- Endpoint: [VOTRE RÉPONSE]
- User-Agent: [VOTRE RÉPONSE]
- Payload envoyé: [VOTRE RÉPONSE]

Payload secondaire:
- Emplacement: [VOTRE RÉPONSE]
- Exécution: [VOTRE RÉPONSE]

--- INDICATEURS DE COMPROMISSION ---
Fichiers:
```

```
- [LISTE DES FICHIERS CRÉÉS]
```

Réseau:

- IP: [VOTRE RÉPONSE]
- Port: [VOTRE RÉPONSE]
- URL: [VOTRE RÉPONSE]

Mutex: [VOTRE RÉPONSE]

--- RECOMMANDATIONS ---

1. Blocage réseau: [Commande iptables]
2. Nettoyage: [Commandes de suppression]
3. Détection: [Règle simple pour détecter ce trojan]

BONUS : Simulation C2 complète (Optionnel)

Pour voir la communication C2 en action, vous pouvez simuler un serveur:

Étape 1 : Lancer le serveur C2 de test

Terminal 1:

```
cd /root/Cours/MalwareAnalysis
python3 fake_c2_server.py
```

Étape 2 : Capturer le trafic localhost

Terminal 2:

```
sudo tcpdump -i lo -A -s 0 'port 8080' | tee /tmp/c2_capture.txt
```

Étape 3 : Exécuter la version test du trojan

Terminal 3:

```
cd /root/Cours/MalwareAnalysis/sample
rm -f /tmp/.trojan_mutex_A5B3C2D1
python3 trojan_test_localhost.py
```

Étape 4 : Analyser la capture

```
cat /tmp/c2_capture.txt
```

Vous verrez:

- La requête POST complète avec victim ID
 - Le User-Agent suspect
 - La réponse HTTP du C2
 - La commande DOWNLOAD envoyée
-



Nettoyage

```
# Supprimer persistance
rm -f ~/.config/autostart/update-service.desktop
rm -f ~/.local/share/svchost

# Supprimer mutex
rm -f /tmp/.trojan_mutex_A5B3C2D1

# Supprimer payload
rm -f /tmp/.payload.sh

# Nettoyer les fichiers de test
rm -f /tmp/c2_capture.txt /tmp/c2_localhost.pcap
```